

Data Security

Dr. Mohamad Aljnidi

Ph.D in Network Security

Syrian Virtual University

BIT – ITI410 – F11

Definition of Security

- In a narrow sense (information system security):
 - Confidentiality.
 - Integrity.
 - Availability.
- In a broad sense:
to protect the system from all threats.

Security Guidelines and Standards

- ISO13335: Guidelines for the Management of IT Security (GMITS).
- ISO15408: IT Security Evaluation Criteria (CC: Common Criteria).
- ISO17799: Code of practice for information security management.
- National standards:
 - TCSEC (US - Orange Book, Red Book).
 - ITSEC (Europe).
 - CTECPEC (Canada).

Orange Book Summary

- Trusted Computer System Evaluation Criteria (TCSEC).
- Categories range from D (Minimal Protection) to A (Verified Protection).
- Examples from C1 (Discretionary Security Protection):
 - Discretionary Access Control.
 - Username and password protection.
 - Periodic integrity checking of TCB.
 - Security documentation.
 - Earlier versions of UNIX.

Security Design Procedure

- Formulate an executive policy.
- Conduct risk analysis and decide on risk management.
- Decide on security measure:
 - Prevention.
 - Detection.
 - Recovery.

Security Policy

- Set of rules that an organization establishes in order to maintain the necessary security level.
- In the narrow sense, security policy regards settings (operating system, firewall, router, ...etc.)
- In the broad sense, security policy regards the entire system (operation, audit, management, ...etc.)

Advantage of Having a Security Policy

- Consensus of the system security can be obtained.
- Employees become security conscious, and understand the risk.
- The duty and the responsibility of each person can be defined.
- Effective and appropriate Security can be achieved with minimum cost.
- Security risks that cannot be countered using security tools can be controlled.

Creating Security Policy Documents

- Phase1 - Establishing Executive Policy.
 - General orientations: declaration – objective – definition – terms – scope – management – compliance – penalties - ...etc.
- Phase2 - Risk Analysis and Management.
 - Conduct risk analysis to decide about security measures and their management.
- Phase3 - Establishing Standards.
 - General rules and regulations (the password creation rule).
- Phase4 - Establishing Procedures.
 - Specific details of each standard are described in different documents according to departments and job description (password creation specifications for users and those for administrators)

Technical Considerations (1/2)

(When Writing a Security Policy)

- Accessible to anyone in the organization.
- Easy to understand and doable.
- Documented, applied, maintained and up-to-date.
- In conformance with the applicable policies and laws, and the applied roles and privileges.
- Detailed analysis of potential threats and the feasibility of various security measures.
- Clear answers to “who should do what, why, how and at what time?”.

Technical Considerations (2/2)

(When Writing a Security Policy)

- Consistent with the level of acceptable risk.
- Clear security measures that mitigate threats.
- Privileged accounts are kept to a minimum.
- Most recent software security patches.
- Authentication and authorization functions.
- Suitable physical security installations.
- Fix the main roles and activities.
- Implemented regarding to the available materials and resources.

Interaction Considerations (When Writing a Security Policy)

- Administrative officials must:
 - Identify areas under their control.
 - Define and document the resources.
 - Establish acceptable levels of risk (data sensitivity – operation criticality – resource availability – potential misuse).
- Users must:
 - Become security-aware.
 - Protect the resources under their control (access passwords, computers, and data they download).

Sample of Security Policy Document:

Executive Policy

- Purpose and scope.
- To Whom the Policy Applies.
- Components and Hierarchy of the Policy.
- Definitions of Terms.
- Organization, Members, Tasks and Responsibilities of the Information Security Committee.
- Information Security Management.
- Penalties for Violations.
- Effective Date.

Sample of Security Policy Document: User Authentication Standard

- Objectives.
- Persons involved.
- Equipment and systems.
- Rules to follow:
 - Security through user authentication.
 - Equipment and System selection.
 - Password, default password, forgotten passwords and one-time password.
 - Biometrics.
- Exception, penalties, disclosure and revisions.

Risk Management: Introduction

- Risk: uncertainty of outcome of actions and events, whether positive opportunity or negative threat.
- Risk management: identifying and assessing risks (the “inherent risks”) and then responding to them.
- Risk appetite: the amount of risk which is judged to be tolerable and justifiable.

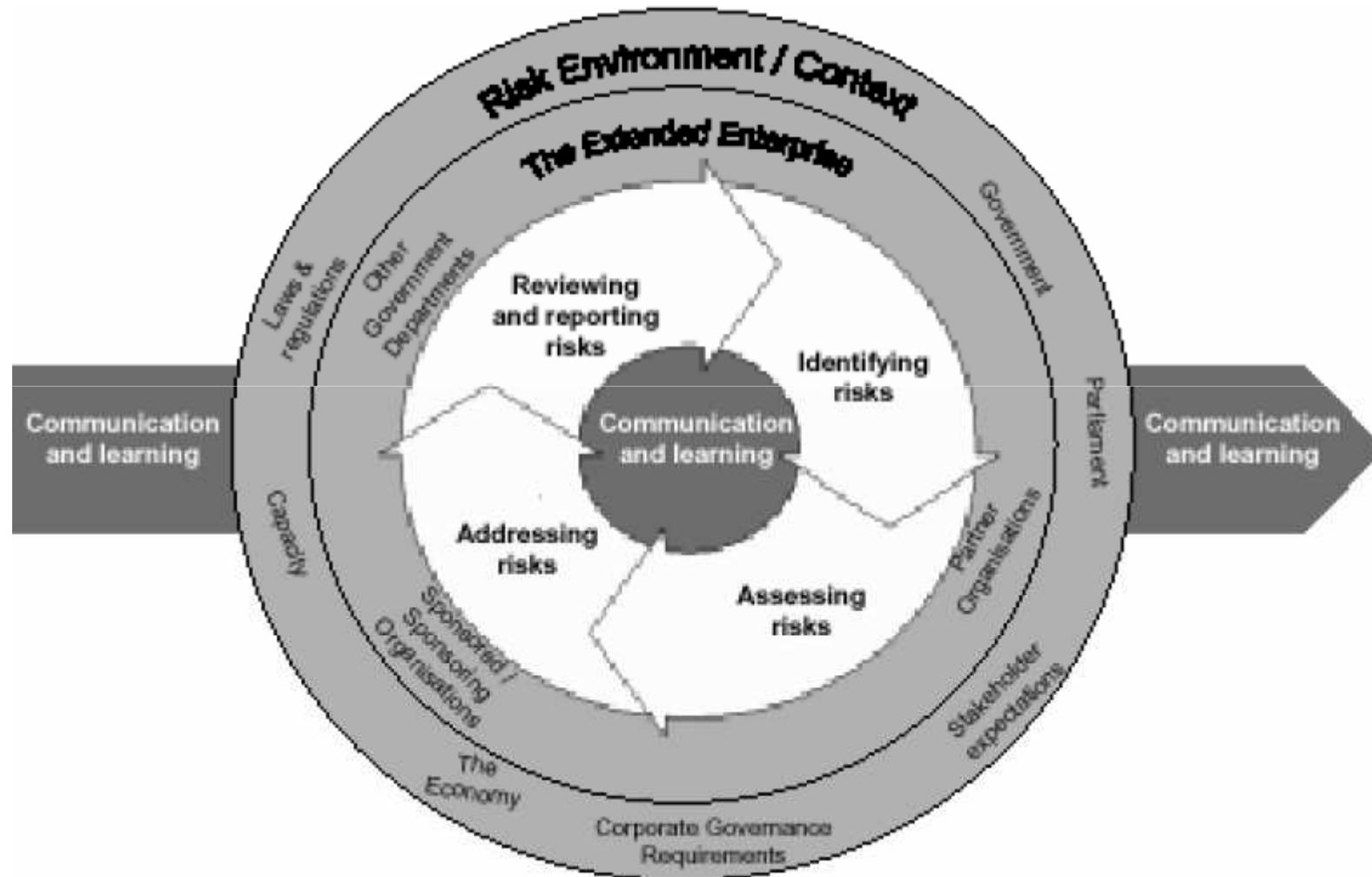
Response to Risk

- Internal control within the organization:
 - Tolerating the risk.
 - Treating the risk:
 - Constrain to an acceptable level.
 - Taking advantage of opportunities.
 - Transferring the risk.
 - Terminating the activity.
- The residual risk (exposure) should be within the risk appetite.

Managing Risk

- Consideration to the context and risk priorities of partners.
- Integration at strategic and operational levels (top-down).
- Staff awareness and training at each level (managers).
- Part of the business systems (embedded strategy and policy).

The Risk Management Model



The Risk Management Model

- Balancing of interacting elements (non-linear).
- The management of one risk may have an impact on another (simultaneous).
- Risk appetite has to be defined (overlay).
- Stages do not necessarily synchronise for all risks.
- The core risk management process takes place in a context (key inputs).

What is Risk Analysis?

- Objective:
 - Identify threats and vulnerabilities.
 - Avoid security failure (business loss).
 - Total cost = direct loss + indirect loss.



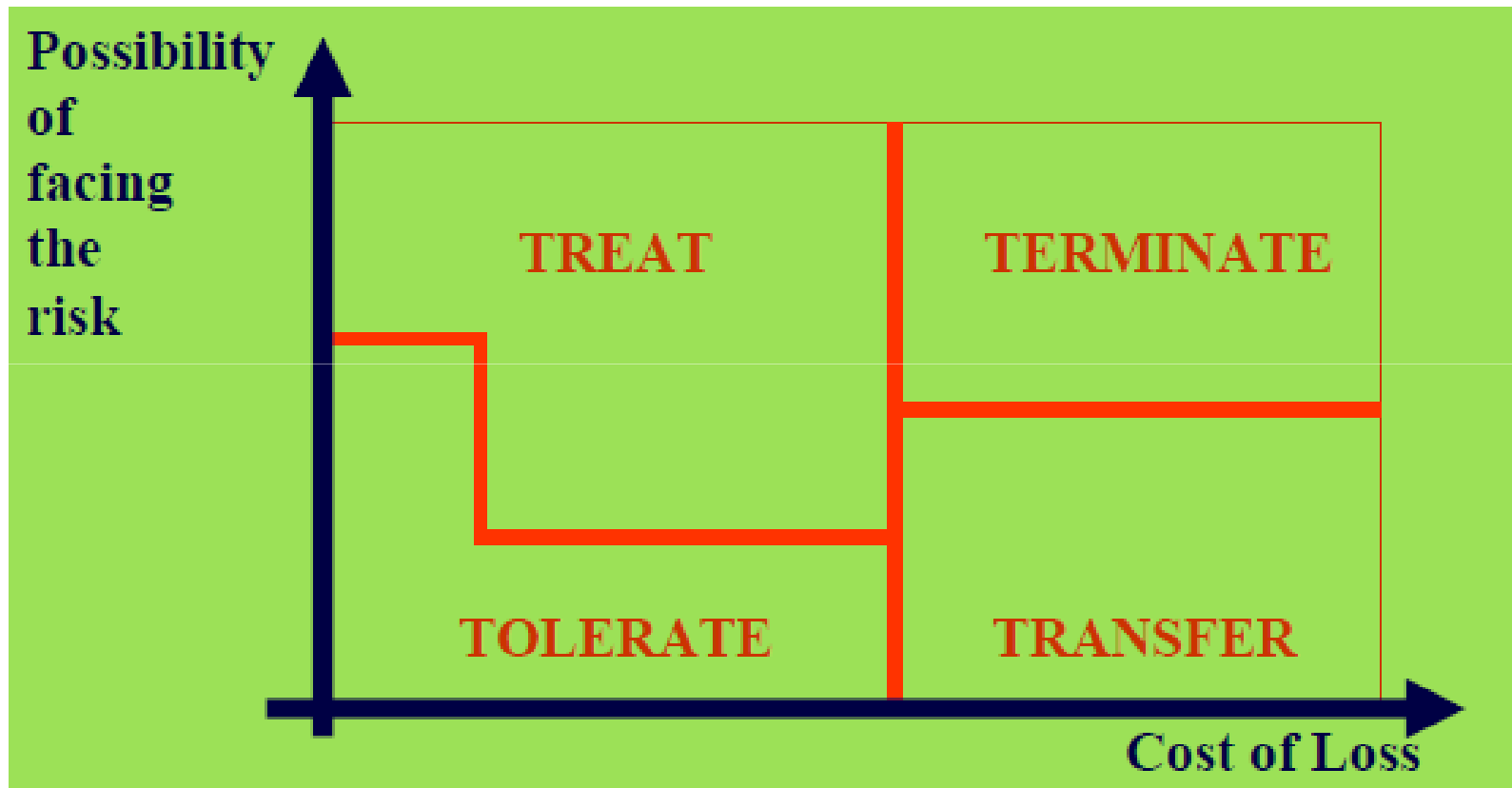
Identifying Risk

- To know what risks and how to evaluate them.
- First step in building risk profile.
- No single way; documentation is critical.
- Two distinct phases:
 - Initial: new to risk analysis, new organization, new project or new activity.
 - Continuous (routine business element): new risks, changes in existing risks, or risks ceasing to be relevant.
- Two most commonly used approaches:
 - Commissioning a risk review.
 - Risk self-assessment.

Risk Appetite

- Essential to consider before addressing risk.
- Tolerable level of exposure in case of a threat: finding a balance between cost of constraining risk and cost of exposure.
- Readiness to obtain benefits in case of an opportunity: comparing the value of potential benefits with potential losses.
- Unavoidable risk + unreachable risk appetite => contingency plan.

Addressing Risk (Case of Threats)



Addressing Risk (Case of Threats)

- Constraining threats and taking advantage of opportunities (part of internal control):
 - **Tolerate**: tolerable exposure – limited ability (contingency plan) – disproportionate cost.
 - **Treat**: most cases – constrain to acceptable level.
 - **Transfer**: insurance / third party – to reduce exposure / limited capability – non-transferable risk (e.g.: reputational).
 - **Terminate**: limited option in government sector.
 - **Take the opportunity**: considered when tolerating, treating or transferring the risk:
 - Exploit positive impact while mitigating threats.
 - Circumstances with positive opportunities and no threats.

Risk Analysis Approaches

- Baseline: Apply a set of safeguards.
- Detailed: Identification, evaluation and assessment.
- Follow-up combined: Baseline and detailed.
- Informal: Experience of individuals.

Risk Analysis Approaches (Comparison)

	Baseline Approach	Detailed Approach	Follow-up Approach	Informal Approach
Advantages	Less Cost and time	Near complete	Focus attention to important assets	Least cost and time
Disadvantages	Overlook some factors	Take time and cost	Require skills of baseline and detailed approach	Depends on the skill of the person

Detailed Risk Analysis Approaches

	Level of threats	low (1)			med (2)			high (3)		
	Level of vulnerabilities	low (1)	med (2)	high (3)	low (1)	med (2)	high (3)	low (1)	med (2)	high (3)
Level of assets	1	1	2	3	2	4	6	3	6	(9)
	2	2	4	6	4	8	(12)	6	(12)	(18)
	3	3	6	(9)	6	(12)	(18)	(9)	(18)	(27)

Threats and Vulnerabilities

- Risk analysis requires knowledge of threats and vulnerabilities.
- Threats to computer systems: External / internal.
- Hacker (skilled) vs. cracker (malicious).
- Thousands of hacking tools online.
- Vulnerability: Weakness in organization, computer system or network.

Malicious Code – Trojan Horse

- A trick – a sneak attack – looks harmless to the user.
- Security-breaking program, disguised as something benign.
- Spread in the guise of anything people find desirable.
- Have no way to replicate automatically.

Malicious Code – Trojan Horse

- To avoid: Be certain of both source and content of anything you download.
- To eliminate: Re-installation – anti-virus – anti-Trojan.

Malicious Code – Viruses

- Software programs, deliberately designed to record, corrupt or delete data.
- Some are benign but they use resources anyway.
- Spread themselves depending on host programs, to computers directly, and throughout the Internet.

Malicious Code – Viruses

- Detected by user through signs of bad operation.
- Email virus: Automatically mails itself (worm?).
- Worms spread over networks without host programs, by controlling other software, and exploiting security holes.
- To avoid: Security awareness, security patches, up-to-date anti-virus and removal tools.

Malicious Code – Mobile Code

- Java applet:
 - Interpreted code: Every instruction examined then executed.
 - If not trusted according to security policy: Sandbox to restrict use of system resources (works badly with lot of bugs).

Malicious Code – Mobile Code

- ActiveX: Check made to see if should be executed (Microsoft's Authenticode system: digital signature verification).
- JavaScript:
 - Every vendor handles security in a different way.
 - Fundamental problem: Foreign code (somebody else's machine at risk).

Network Attacks – Collect of Information

- Foot printing: Collect public functional and financial information.
- Scanning:
 - To detect TCP/UDP services, architecture and connections.
 - IP and port scanning (tools available).
- Enumeration: accounts – devices – folders ...etc.

Network Attacks – Collect of Information – Port Scanning

- The three-way handshake procedure

```
Client → SYN  
Server → SYN-ACK  
Client → ACK
```

- The attack procedure

```
Repeat for all Ports  
Client → SYN  
If (Server → SYN-ACK) then Port  
Else  
    if (Server → RST-ACK) then No Port  
    Client → ACK
```

Network Attacks – Sniffing

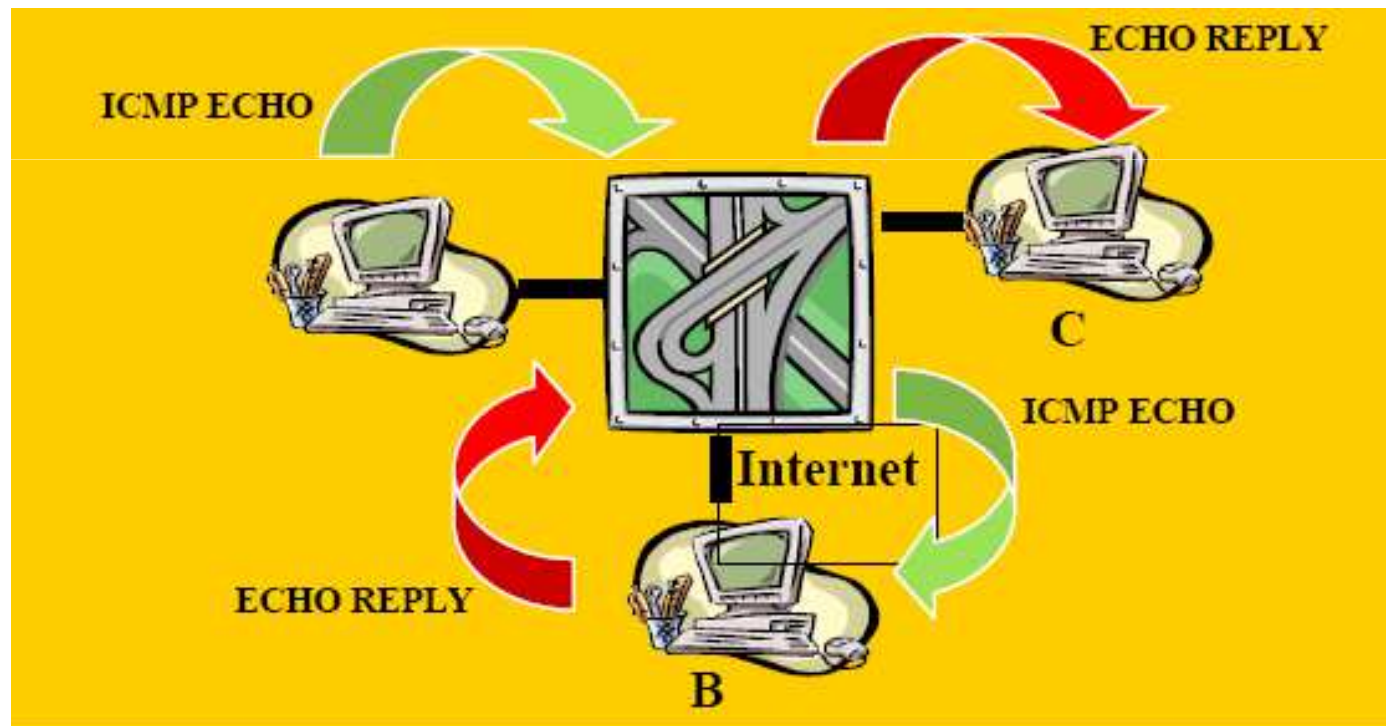
- Sniffer: program/device that monitors.
- Sniffs source, destination and content.
- Extra features (e.g: capture passwords).
- MAC (Media Access Control) address?
- Wired: sniffer runs in promiscuous mode.
Originally for troubleshooting.
- Wireless: simply listenning status.
- Most commonly show up within closed business networks.

Network Attacks – IP Spoofing

- Spoofing: faking the source address.
- Generally, to disguise the location from which the attack originates.
- Required in session hijacking (faking someone's identity in order to take over a connection).
- IP spoof: protects the identity of the attacker.

Network Attacks – Denial of Service: ICMP-echo Flooding

- DoS and DDoS.
- Flooding / harmful commands or data.



Network Attacks – Smurf Attack

- A request to a network of computers. Replies, possibly increased, go back to one computer (fake address).
- Broadcast storm: a broadcast packet of which the return address is the broadcast address.
- Hacker is invisible (original packets are untraceable).

Network Attacks – SYN Flooding

- Ties up resources by connection requests that are never completed.
- For every fake SYN packet (no ACK from client), further resources are tied up, reaching the limits.
- A hacker often sets up several client computers (slaves / zombies) with a master point for launching attack.

Network Attacks – Hijacking

1. When, Client → Server: SYN
 - a. Hacker → Server: false RST-SYN
 - b. Hacker → Client: false ACK
2. Thus, Server → Client: new SYN-ACK (responding to 1.a)
 - a. Hacker → Server: ACK
 - b. Server → Hacker: ACK (Established with Hacker)
3. Client → Hacker: ACK (Established with Hacker) (responding to 1.b)

Network Attacks – Ping of Death

- Fragmentation of a TCP/IP packet with a theoretical length greater than 65536 bytes may result in operating system crashing when fragments add up.
- On older versions of Windows:
`ping -l 65550 VICTIM`
- Most systems have been patched to prevent this bug.

Network Attacks – DNS Spoofing

- Forcing a DNS "client" to generate a request to a "server", then spoofing the response from the "server".
- Hacker may force a duplicate reply.
- Most DNS servers support "recursive" queries. Hacker spoofs the response while victim server sends queries.
- DNS servers will "cache" information for a certain amount of time.

Social Engineering

- Interpersonal manipulation (criminally / professionally).
- Disguised telemarketing: attacker tricks us into providing "sensitive" information.
- A common hacker method is to pretend to be conducting a survey.
- The most popular method involves pretending to be a user who has trouble.

Social Spying

- Using observation to acquire information.
- Ex1: snooping on people as they actively type their user information.
- Ex2: most offices have at least a few people who post passwords on or near their computer monitors.

Security Measures

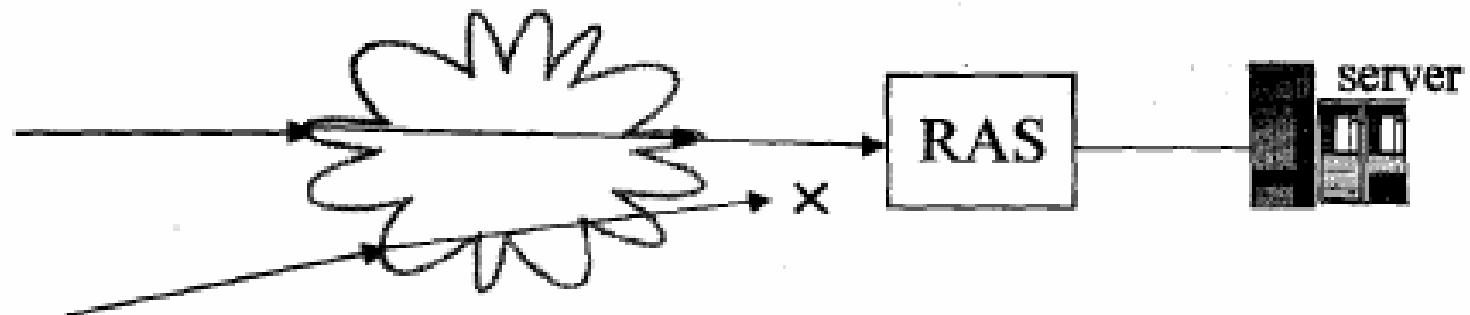
- Technical:
 - Network.
 - OS and DB.
 - Application.
- Operational:
 - Training.
 - Incident response.

Types of Security Measures

	Prevention	Detection	Recovery
Network	• leased line • call back • packet filtering (router) • firewall • switching hub	• firewall, router (log)	
Operating system Database	• user authentication • access permission	• access log	• backup
Others	• one time password • encryption • anti-virus	• anti-virus (pattern match) • encryption (digital signature)	

Network-Related Security Measures

- Physical access control



Unauthorized persons are physically blocked from establishing a circuit.

- Logical access control



Whether data should be allowed to go through is decided from its header and/or data content

Network-Related Physical Security Measures

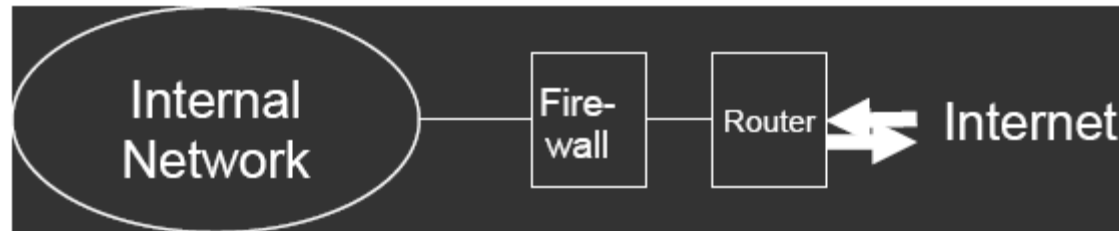
- Access points are controlled and monitored. Other points are blocked.
- WAN:
 - Leased line: a fixed circuit is established between two points.
 - Call back: only authorized users can establish a circuit.
- LAN:
 - Switching hub: data are transmitted only to the destination computer (port).

Network-Related Logical Security Measures

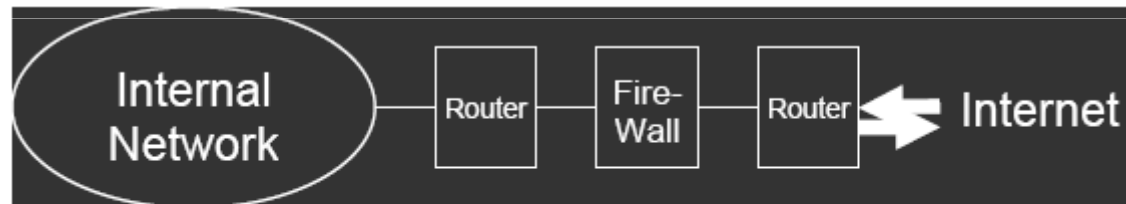
- Packet header filtering by router: filtering addresses and ports (pessimist / optimist).
- Content filtering by firewall:
 - A program or hardware device that filters the information flowing in and out of a private network or computer system connected to the Internet. It implements security rules.
- Methods:
 - Packet filtering: analyzed against filters.
 - Proxy service: information retrieved then sent.
 - Stateful inspection: comparison of certain key parts against a trusted DB.

Firewall Placement

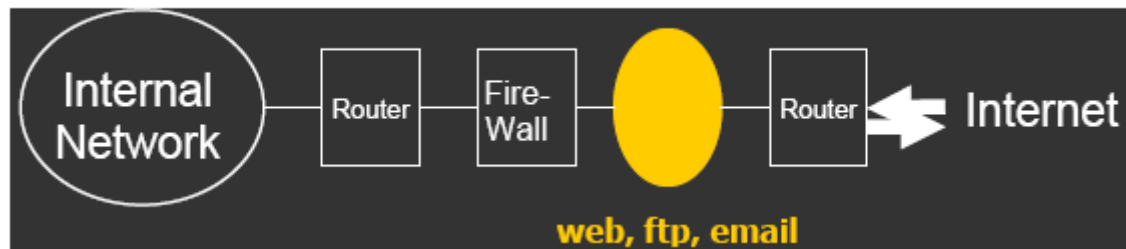
Screened Host



Screened Subnet



DMZ (De-Militarized Zone)



Common Intrusions

A Firewall May not Help

- Remote login.
- Application backdoors (remote access).
- SMTP session hijacking (to send spam).
- Operating system bugs (backdoors).
- Denial of service.
- E-mail bombs (usually personal).
- Macros (hacker's scripts).
- Viruses (Anti-virus software should be installed).
- Spam (once email accepted).
- Redirect bombs (sending to a different router).
- Source routing (disabled by most firewall products by default).

Intrusion Detection System (IDS)

- Detects attacks to computer systems, mainly through the Internet (prone to false alarms).
- Used where conventional firewalls fail, especially detecting internal attacks.
- Components:
 - Sensors: generate security events.
 - Console: monitors events and alerts, and controls sensors.
 - Central engine: events recorded in a DB – rules for generating alerts.

IDS Categorization

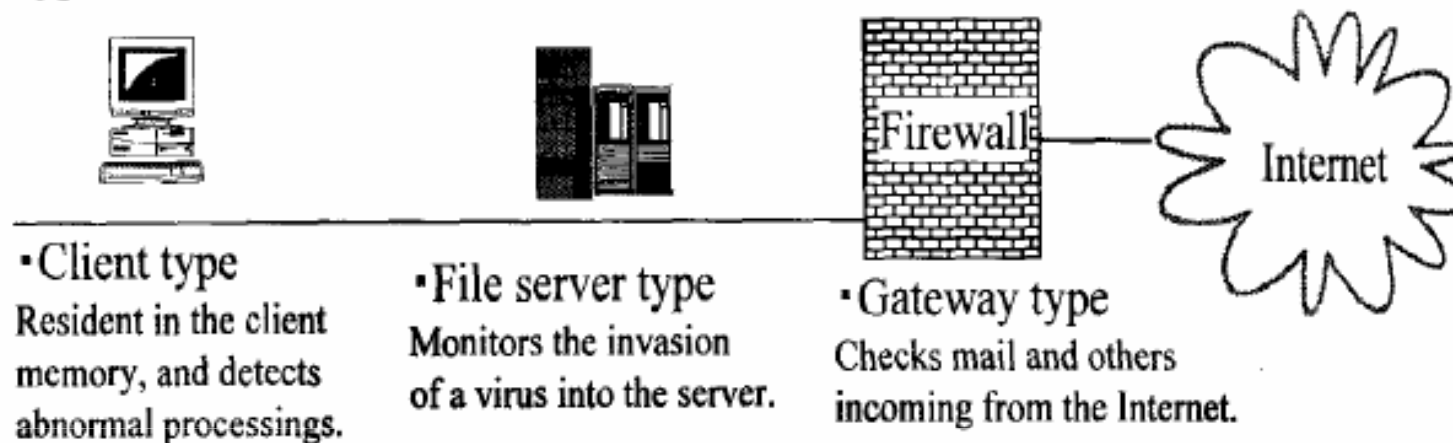
- Misuse detection (DB of attack signatures) **vs.** Anomaly detection (normal baselines).
- Network-based “NIDS” (packets analyzed) **vs.** Host-based “HIDS” (each host’s activity analyzed).
- Passive system (detect, logs and alerts) **vs.** Reactive system (also responds: log off user — reprogram firewall ...etc.).

Intrusion Prevention System (IPS)

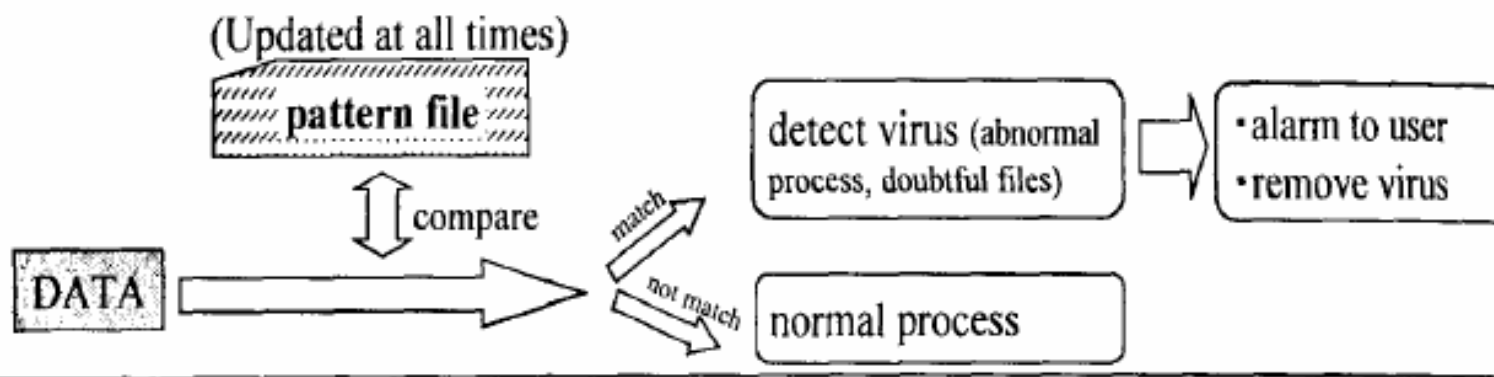
- A firewall which combines network-level and application-level filtering with a reactive IDS.
- Best practices recommend that the firewall be explicitly configured to DENY all incoming traffic and then we open up holes, where the IDS would come.
- IDS also identifies malicious traffic originating from inside the network.

Using Anti-Virus

• Types of anti-virus software



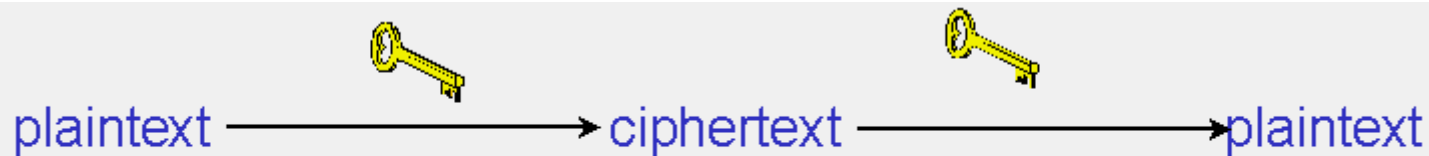
• Virus detection and removal by pattern-matching method



Cryptography

- Purpose: writing in secret code.
- Use: authentication – privacy – confidentiality – integrity – non-repudiation.
- Schemes:
 - Secret-key (symmetric) cryptography.
 - Public-key (asymmetric) cryptography.
 - Hash functions.

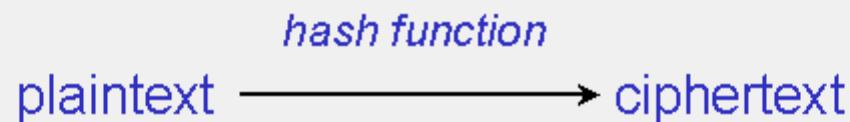
Types of Cryptographic Algorithms



A) Secret key (symmetric) cryptography. SKC uses a single key for both encryption and decryption.



B) Public key (asymmetric) cryptography. PKC uses two keys, one for encryption and the other for decryption.



C) Hash function (one-way cryptography). Hash functions have no key since the plaintext is not recoverable from the ciphertext.

Secret-Key Cryptography – Stream Ciphers

- Operates on a single bit, byte or word.
- Key is constantly changing → different ciphertext for same plaintext.
- Most important types:
 - Self-synchronizing: a bit in the keystream is function of the previous n bits (error propagation).
 - Synchronous: same keystream generation function at sender and receiver (keystream repetition).

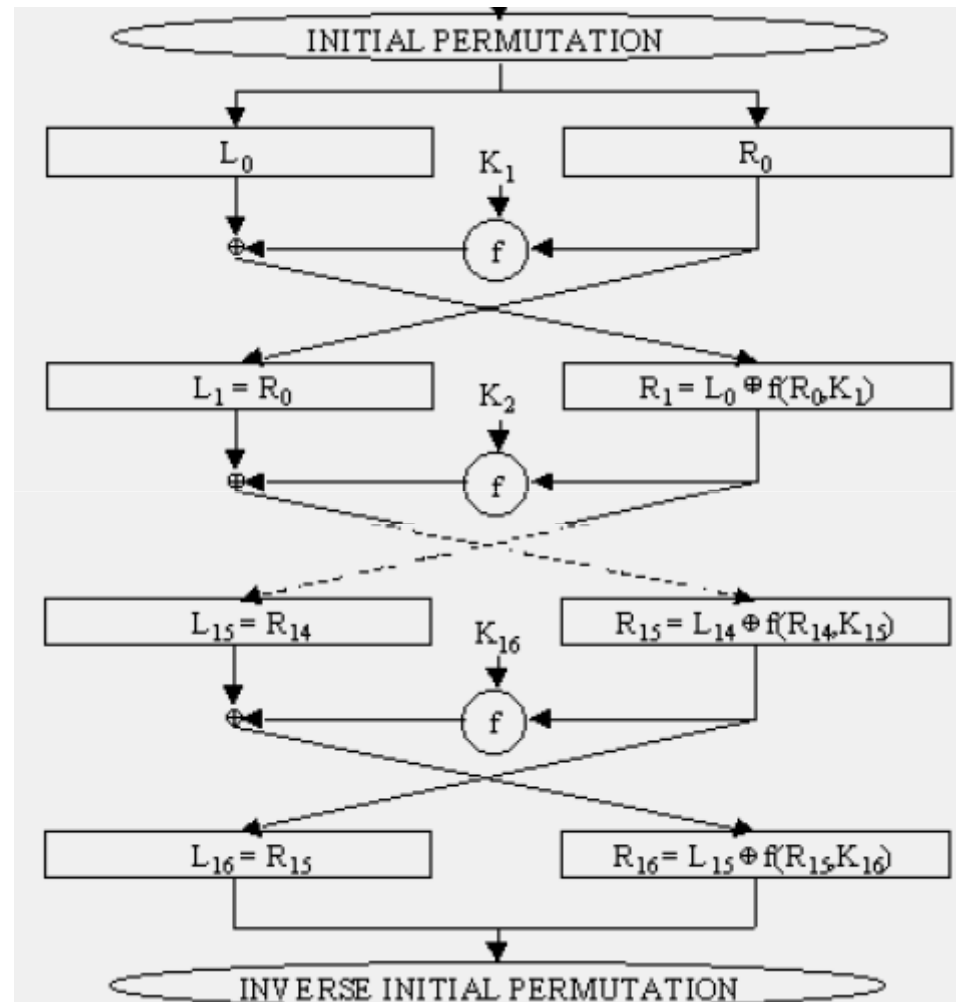
Secret-Key Cryptography – Block Ciphers

- Encrypts one block of data at a time.
- Most important modes:
 - Electronic Codebook (ECB): two identical plaintext blocks always generate the same ciphertext block.
 - Cipher Block Chaining (CBC): plaintext block is XORed with the previous ciphertext block prior to encryption.
 - Cipher Feedback (CFB): data may be encrypted in units smaller than the block size, working as a self-synchronizing stream cipher for a block.
 - Output Feedback (OFB): prevents the same plaintext block from generating the same ciphertext block, working as a synchronous stream cipher for a block.
- Same key + same plaintext → same ciphertext.

Secret-Key Cryptography Algorithms

- Data Encryption Standard (DES): employs DEA (Data Encryption Algorithm); a 64-bit block cipher using a 56-bit key (declared obsolete by NIST in 2004).
- Advanced Encryption Standard (AES): the Rijndael block cipher with variable lengths (128, 192 or 256 bits) of block and key.
- International Data Encryption Algorithm (IDEA): employs a 64-bit block cipher using a 128-bit key.

Overview of DES Operations



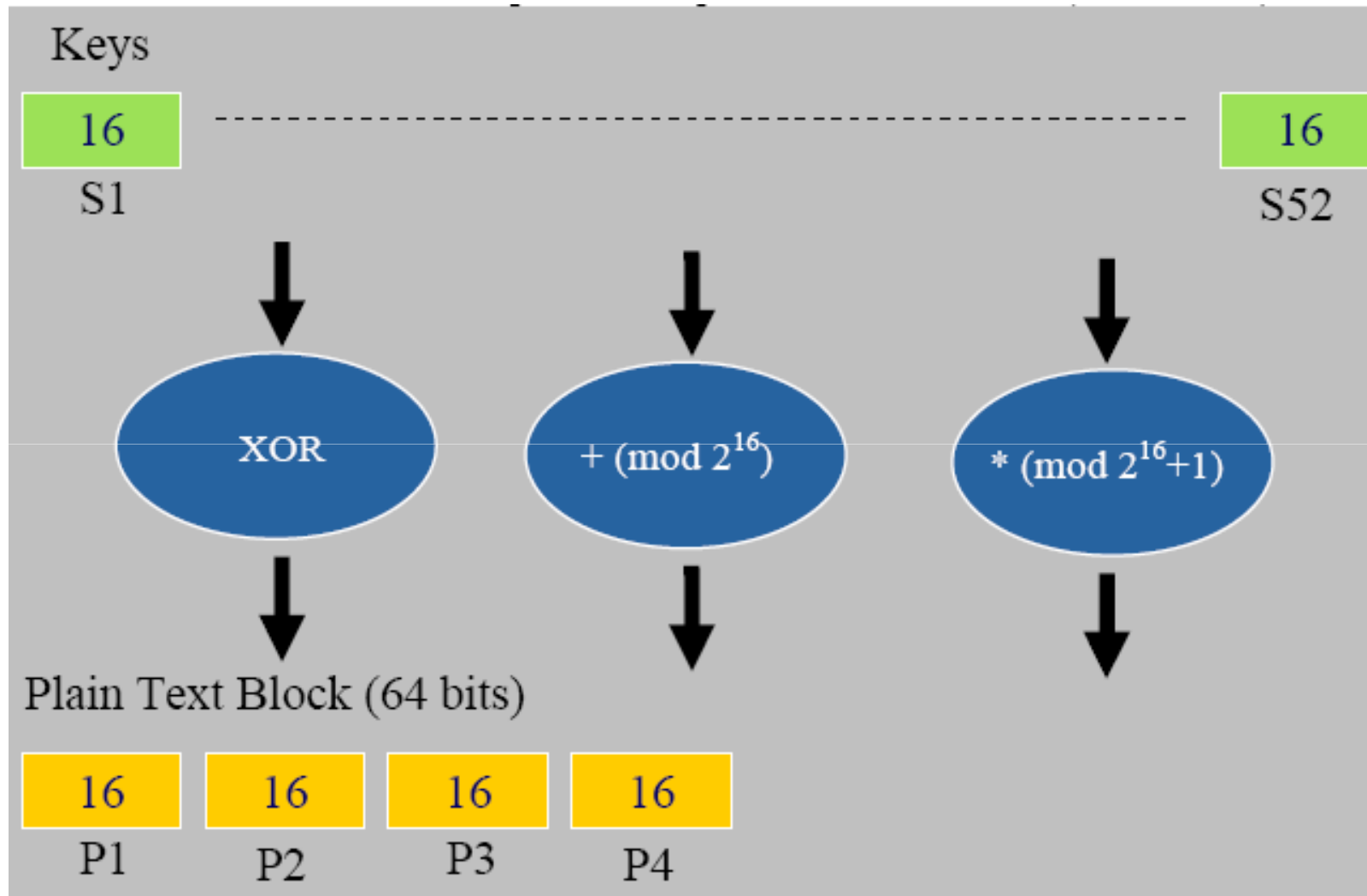
Breaking DES

- Short Key (Moore's Law: computer power doubles every 18 months).
- Used to encrypt words; block entropy reduced.
- Brute-force attack would work.
- RSA Laboratories sponsored a series of cryptographic challenges to prove that DES was no longer appropriate for use.

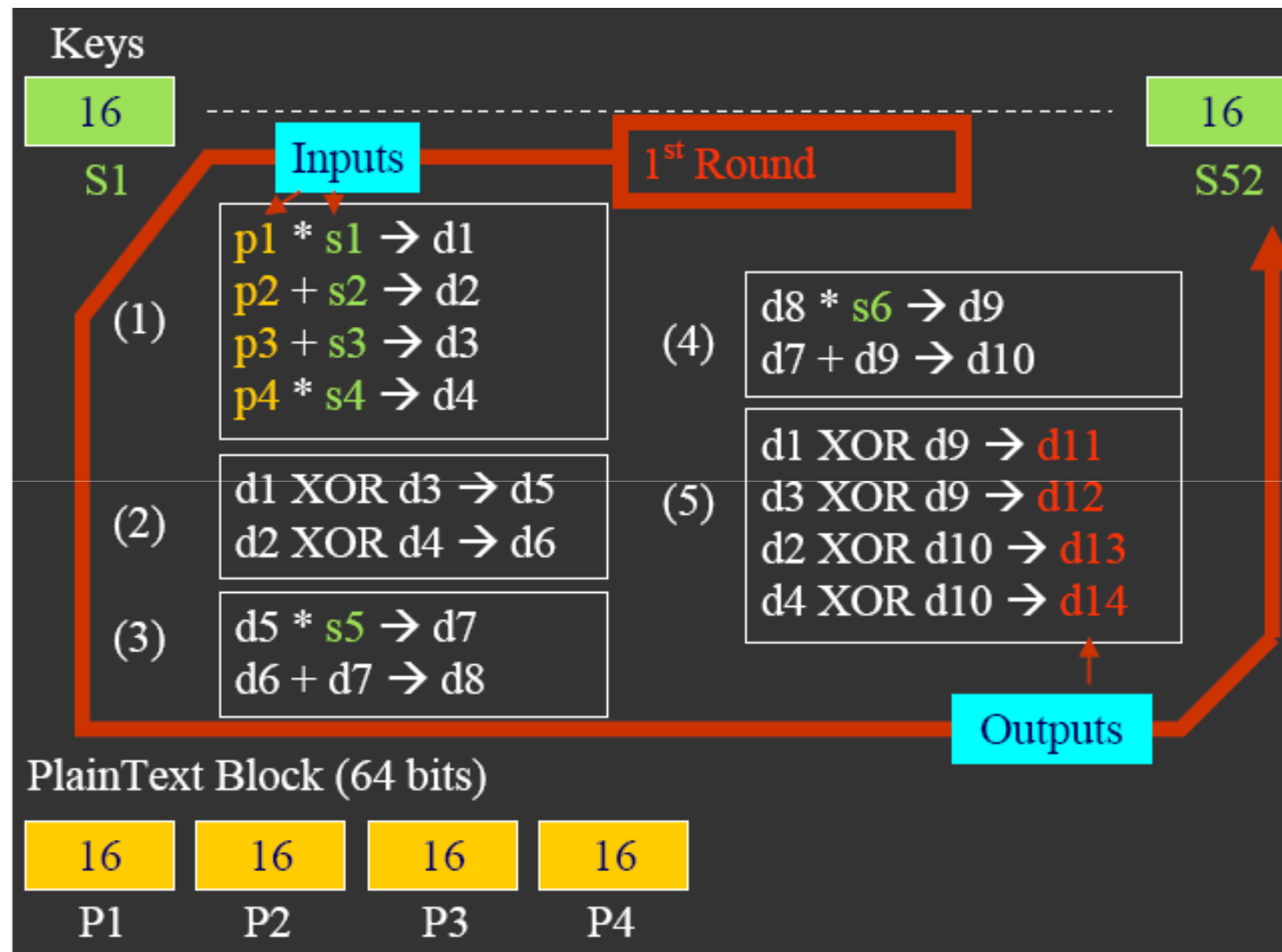
DES Variants

- Multiple keys with multiple passes (DES function is not a group).
- Double DES: meet-in-the-middle attack.
- Triple DES (3DES):
 - Triple Data Encryption Algorithm (TDEA).
 - Three DES passes (encrypt-decrypt-encrypt mode) using up to three keys.
- DESX: input/output XORed with 64-bit key (immune to brute-force only).

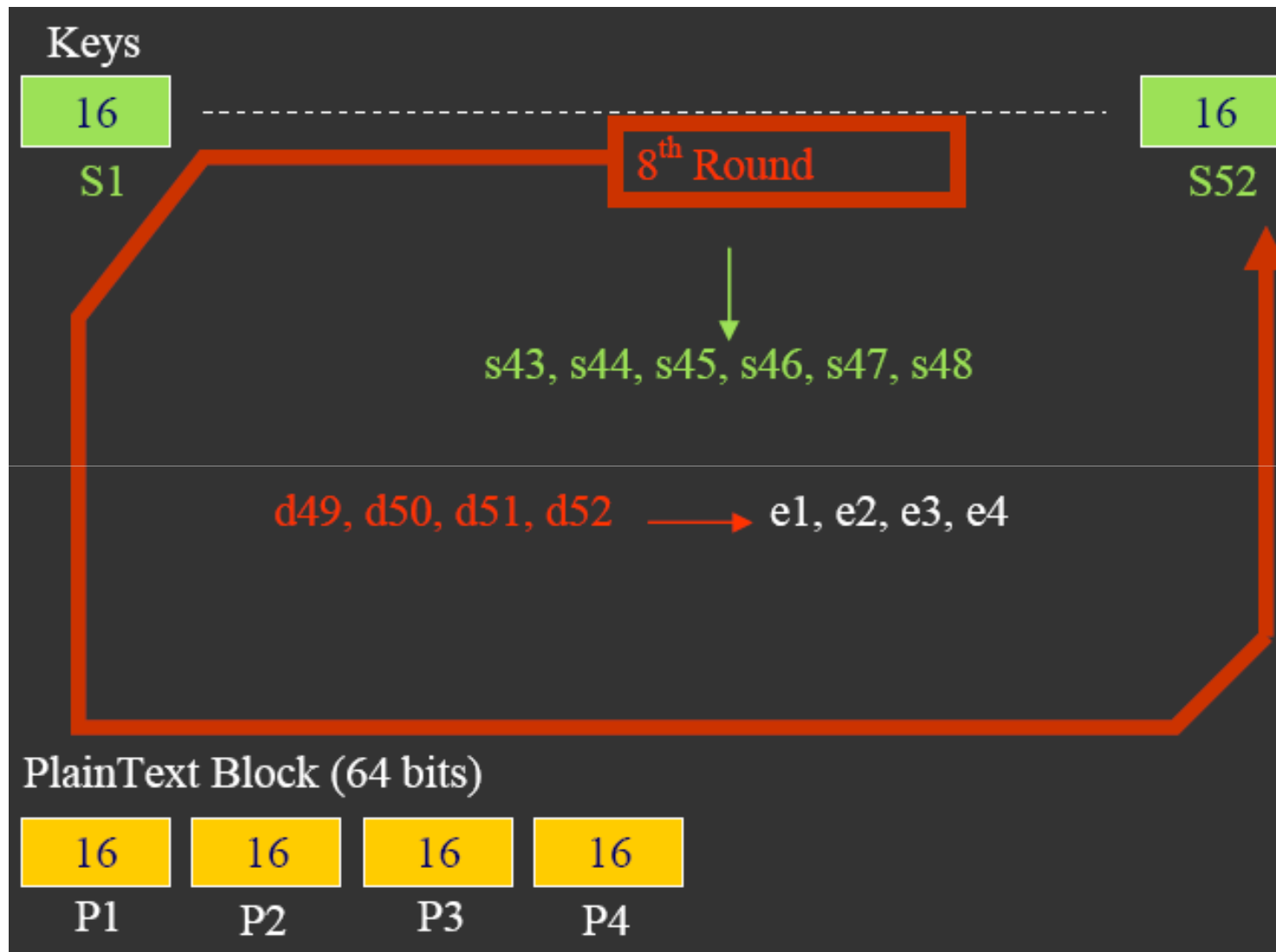
Overview of IDEA Operations



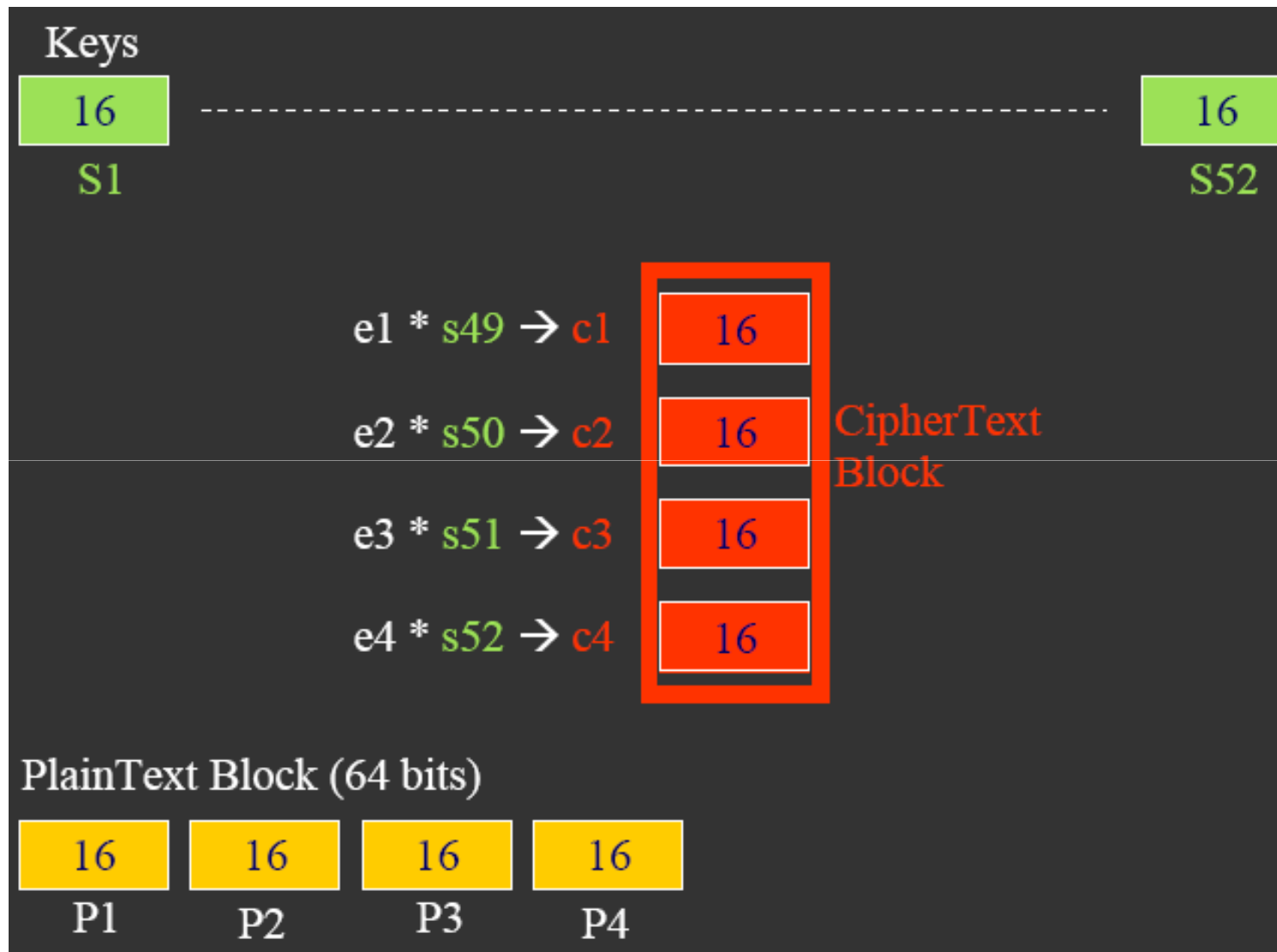
Overview of IDEA Operations



Overview of IDEA Operations



Overview of IDEA Operations



Public-Key Cryptography

- PKC depends upon mathematical functions that are easy to compute whereas their inverse functions are relatively difficult to compute:
 - Multiplication vs. factorization.
 - Exponentiation vs. logarithms.
- Generic PKC employs two keys that are mathematically related although knowledge of one key does not allow someone to easily determine the other key.

Public-Key Cryptography: Asymmetric Cryptography

- One key is used to encrypt the plaintext and the other key is used to decrypt the ciphertext.
- It does not matter which key is applied first.
- One of the keys is designated the public key and may be advertised as widely as the owner wants.
- The other key is designated the private key and is never revealed to another party.
- It is straight forward to send messages under this scheme.
- Encryption, key exchange and digital signature.

Public-Key Cryptography Algorithm RSA

- RSA uses a variable-size encryption block and a variable-size key.
- Key pair is derived from 'n'; 'n' is the product of two large prime numbers.
- Public key includes 'n' and 'e'; 'e' is a derivative of the factors of 'n'; it is mathematically hard for an attacker to find the factors of 'n' to detect the private key 'd' by knowing 'e'; 'd' is also a derivative of the factors of 'n'. $C = P^e \bmod n$; $P = C^d \bmod n$.
- Ability of computers to factor large numbers is improving! Users can easily increase the key size.

Other Public-Key Cryptography Algorithms

- Diffie-Hellman: secret-key exchange.
- Digital Signature Algorithm (DSA): NIST's Digital Signature Standard (DSS).
- ElGamal: key exchange.
- Elliptic-Curve Cryptography (ECC): PKC with small keys, designed for devices with limited computer power and/or memory (e.g., smartcard, PDA).

Diffie-Hellman Scheme

Alice...

Choose a large random number, x
Send to Bob: $X = g^x \bmod n$
Compute: $K_A = Y^x \bmod n$

Bob...

Choose a large random number, y
Send to Alice: $Y = g^y \bmod n$
Compute: $K_B = X^y \bmod n$

Hash Functions

- Message digests – one-way encryption.
- A fixed-length hash value is computed based upon the plaintext (impossible for either the contents or length of the plaintext to be recovered).
- Used to provide a digital fingerprint.
- Employed to encrypt passwords.
- It is difficult enough to find two files with the same hash.
- It is very hard to create a file that has a given hash value.

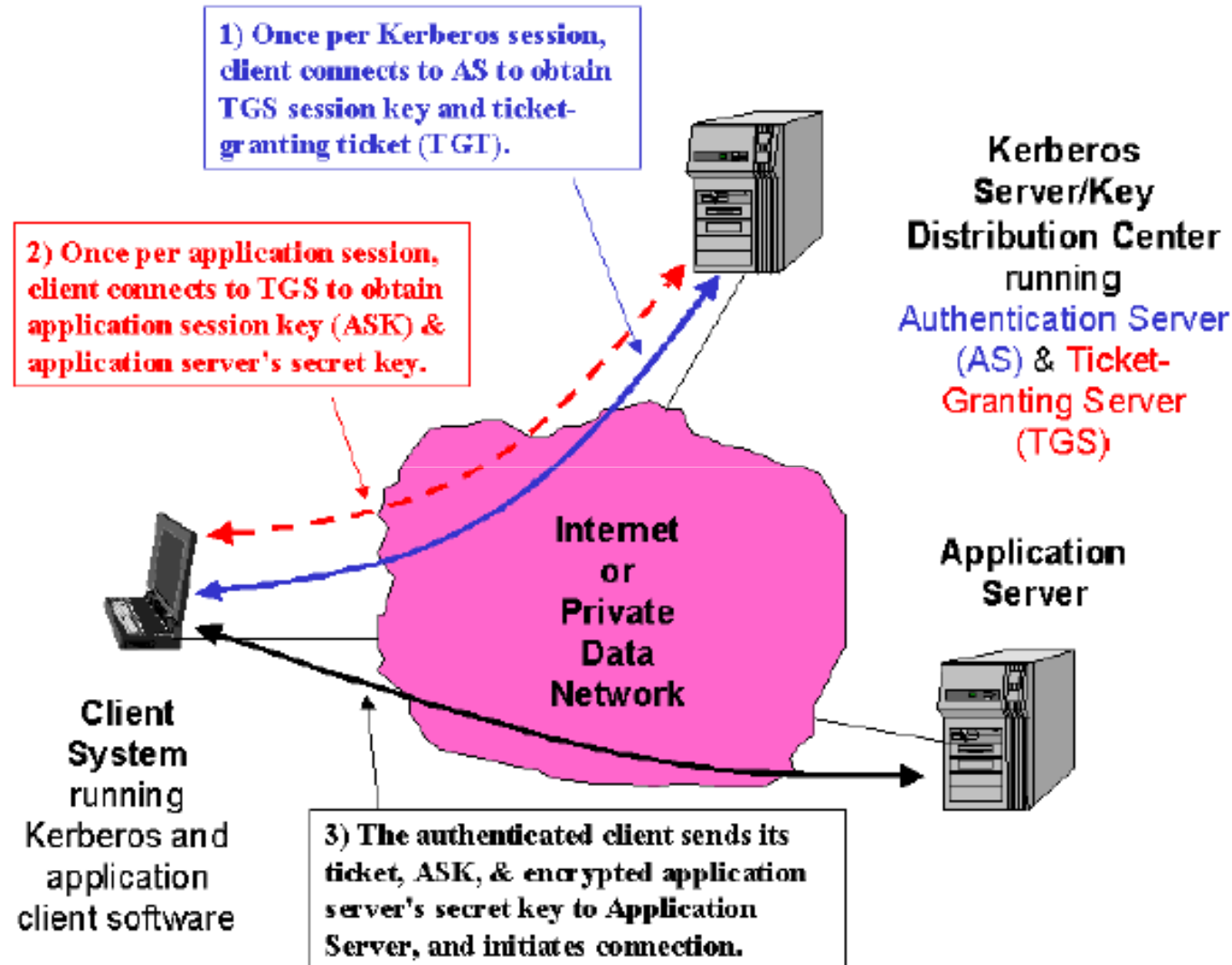
Combining Encryption Techniques

- Digital Envelope:
 - Encrypt message using session, randomly-generated secret-key.
 - Encrypt session key using receiver's public-key.
- Digital Signature:
 - Compute hash value of the message.
 - Encrypt hash value with the sender's private key.

Trust Models: PGP Web of Trust

- A widely used private e-mail scheme based on public key methods.
- A PGP user maintains a local keyring of all trusted public keys.
- Trustworthiness depends upon the “Web of Trust” (up to the user).

Trust Models: Kerberos

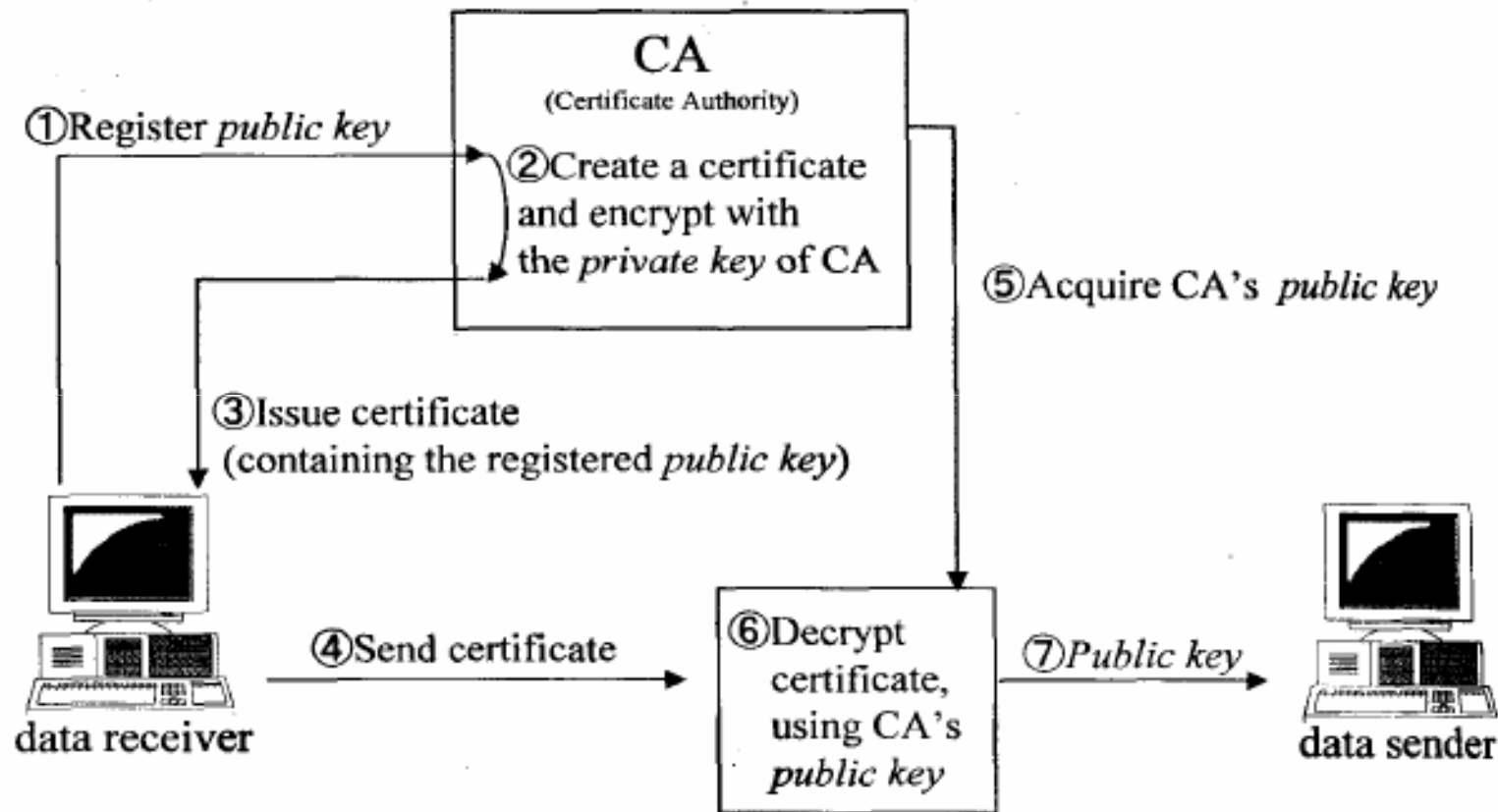


Public-Key Certificates and Certificate Authority (CA)

Contents of an X.509 V3 Certificate.

- version number
- certificate serial number
- signature algorithm identifier
- issuer's name and unique identifier
- validity (or operational) period
- subject's name and unique identifier
- subject public key information
- standard extensions
 - certificate appropriate use definition
 - key usage limitation definition
 - certificate policy information
- other extensions
 - Application-specific
 - CA-specific

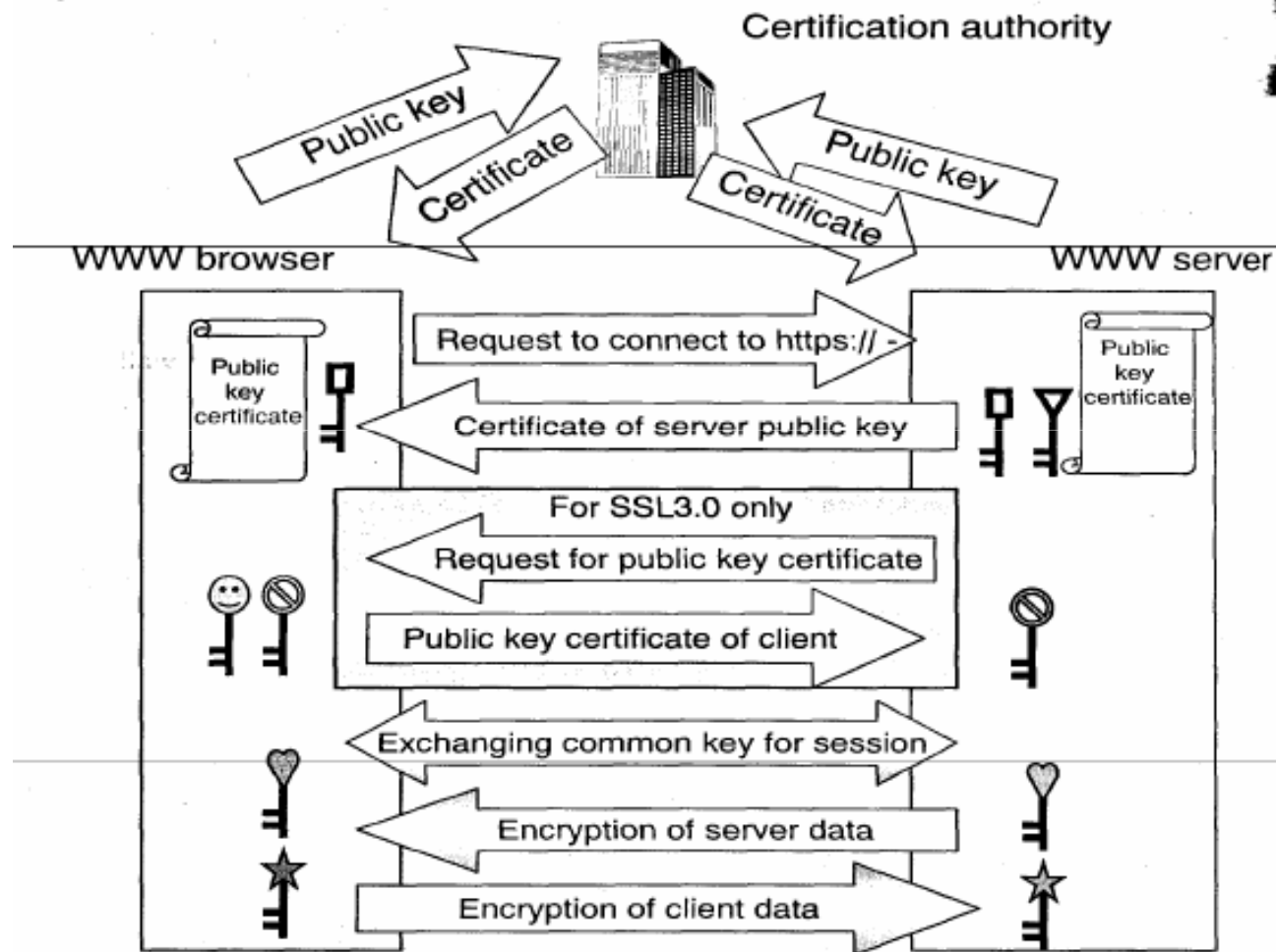
Public-Key Certificates and Certificate Authority (CA)



Secure Protocols: Pretty Good Privacy (PGP)

- A family of cryptographic routines for e-mail and file storage applications.
- PGP can be used to sign or encrypt e-mail messages with the mere click of the mouse.
- When PGP is first installed, the user has to create a key-pair:
 - Public key, advertised and widely circulated.
 - Private key, protected by passphrase.
 - The passphrase has to be entered every time the user accesses his/her private key.

Secure Protocols: Secure Socket Layer (SSL)



Virtual Private Network (VPN)

- Features:
 - Security (firewalls, encryption, IPSec, AAA server).
 - Reliability – scalability – network management – policy management.
- Types:
 - Remote-access VPN: Virtual Private Dial-up Network (VPDN).
 - Site-to-site VPN.